

Subject : Ethical Hacking

# Hackspaining

Lessons ▾Resources ▾For Teams

Log inStart Learning →

## SQL Injection

This is the vulnerable application we will be trying to hack with a **SQL injection** attack.

←→

www.securebank.com

Username

Password

Log in

 **SECURE BANK**

You can trust us with your money, we almost never get hacked.

# Hackspaining

Lessons ▾Resources ▾[For Teams](#)

Log in[Start Learning →](#)

## SQL Injection

●●○●○●○●○●○●○●○●○

←→

www.securebank.com

Username

Password

[Log in](#)

**SECURE BANK**

You can trust us with your money, we almost never get hacked.

Here are the application logs. Watch what happens here when you interact with the vulnerable application.

[→](#)

Application initialized.

Hacksplaining

Lessons ▾Resources ▾For Teams

Log inStart Learning →

SQL Injection

Go ahead and try logging in with the following credentials: Email: user@email.com Password: password

www.securebank.com

Username

user@email.com

SECURE BANK

You can trust us with your money, we almost never get hacked.

Password

password

Log in

An error occurred

Credentials did not match, login failed.

Application initialized.User is attempting to login...  
SELECT \* FROM users WHERE email = 'user@email.com' AND password = 'password'  
Credentials did not match, login failed.

Hacksplaining

Lessons ▾Resources ▾For Teams

Log inStart Learning →

SQL Injection

Okay, so guessing the password didn't work. Let's try adding a quote character after the password: Email: user@email.com Password: password'

www.securebank.com

Username

user@email.com

SECURE BANK

You can trust us with your money, we almost never get hacked.

Password

password'

Log in

An error occurred

An unexpected error occurred.

Application initialized.User is attempting to login...  
SELECT \* FROM users WHERE email = 'user@email.com' AND password = 'password''  
Invalid SQL: SELECT \* FROM users WHERE email = 'user@email.com' AND password = 'password''

## SQL Injection



Hmmm. The application crashed with an unexpected error. What could that mean? →

Application initialized.

## SQL Injection



This is what the application code looks like behind the scenes. →

code

```
SELECT *  
FROM users  
WHERE email = ''  
AND password = ''
```

Application initialized.

Hacksplaining

Lessons ▾Resources ▾For Teams

Log inStart Learning →

SQL Injection

Enter the password `password'` and watch the code window.

www.securebank.com

Username

SECURE BANK

You can trust us with your money, we almost never get hacked.

Password

`password'`

Log in

code

```
SELECT *
FROM users
WHERE email = ''
AND password = 'password'
```

Application initialized.User is attempting to login...  
SELECT \* FROM users WHERE email = '' AND password = 'password'  
Invalid SQL: SELECT \* FROM users WHERE email = '' AND password = 'pa

Hacksplaining

Lessons ▾Resources ▾For Teams

Log inStart Learning →

SQL Injection

Enter the following credentials and click "Log in": Email: `user@email.com`  
Password: `' or 1=1--`

www.securebank.com

Username

`user@email.com`

SECURE BANK

You can trust us with your money, we almost never get hacked.

Password

`' or 1=1--`

Log in

code

```
SELECT *
FROM users
WHERE email = 'user@email.com'
AND password = '' or 1=1--
```

Application initialized.

Hacksplaining

Lessons ▾Resources ▾For Teams

Log inStart Learning →

SQL Injection

And we are in! We successfully gained access to the application without having to guess the password, using SQL injection.

www.securebank.com

Welcome back, user@email.com!

Your current balance is \$8,266

SECURE BANK

Initiate a transfer

code

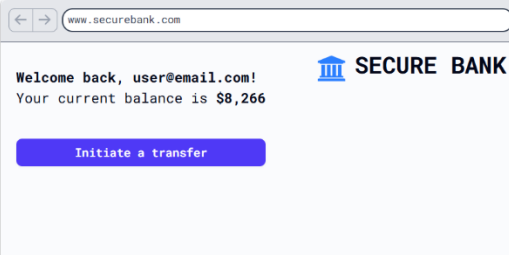
```
SELECT *
FROM users
WHERE email = ''
AND password = ''
```

Application initialized.

## SQL Injection



The `--` characters you entered caused the database to ignore the rest of the SQL statement, allowing you to be authenticated without having to supply the real password.



```
code
SELECT *
FROM users
WHERE email = ''
AND password = ''
```

Application initialized.